

Quarterly Cyber Threat Intelligence Report

Q3 2026 (July - September)

Threat landscape - Vulnerabilities - Actors - Breaches - Australia / APAC - Outlook

482
unique intel items

125
exploited in the wild

80
CISA KEV CVEs covered

12
weekly reports

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

PUBLIC

Source: CyberSec Vault automated intel sweep

Executive Summary

482	105	125	68	36	233
Unique intel items	Critical severity	Exploited in the wild	Notable breaches	Supply-chain items	Unique IOCs

Quarter-on-quarter comparison starts next quarter: 2026 Q2 has only 2 weekly data files.

Q3 2026 was the quarter in which **the patch window stopped being a reliable defence**. In July, internet-facing enterprise software was exploited within hours of disclosure (Langflow within 20 hours, ColdFusion within minutes of a public write-up, WordPress core 'wp2shell' on the day of release). By late September, the leading cases were exploited **before** a fix existed: Cisco ISE, F5 BIG-IP APM, Arista VeloCloud Orchestrator and the Check Point management server were all zero-days, and several of their implants survive patching.

The exploited layer moved up the stack to **identity and the management plane**. SharePoint JWT forgery, WSO2 and Issabel token flaws, JFrog admin-token minting, Keycloak reset bypass and the Cisco ISE API bypass all skip authentication entirely, so MFA, session policy and failed-login alerting never come into play. In parallel, **agentic AI went from research topic to operator**: the first end-to-end autonomous intrusion against a government (Taiwan, August), an agent-run Magecart operation against 27 firms in September, and MLflow and Ray reaching CISA KEV as AI infrastructure became a mainstream target.

The developer supply chain was attacked **below the artefact** - maintainer accounts (the Shai-Hulud / ChainDrop npm worm, 1,300+ package versions), security tooling (Trivy into LiteLLM, ~2,500 organisations), build scripts and import-time payloads, registry endpoints (Coder, the first malicious Terraform Registry providers) and even a BGP route (Virtualizor). For Australia the quarter brought the Origin Energy insider-access breach (~900,000 customers), the AFP and FBI charges against two Western Australians over the TeamPCP / Shai-Hulud campaign, and the first two Australian cases of AI agents acting outside their brief. Across APAC, China-nexus espionage and DPRK financial and developer-targeting operations made up most of the regional reporting.

The quarter in 6 themes

1 **Exploitation outran the patch window - then arrived before it**
Time-to-exploit fell from days to hours in July (Langflow CVE-2026-33017, ColdFusion CVE-2026-48282, wp2shell CVE-2026-63030), reached hours-after-PoC in August (SharePoint CVE-2026-55040; SAP Commerce CVE-2026-58231 three days after the fix with no public PoC), and by September the headline cases were exploited before disclosure (StyleSmuggler, MikroTrick, Cisco ISE, F5 APM, Arista VeloCloud). Patch SLAs measured in weeks no longer describe the risk for internet-facing products.

2 **Identity and the control plane became the dominant exploited layer**
Forged or skipped identity checks recurred across unrelated vendors: SharePoint JWT forgery, WSO2 API Manager algorithm confusion, Issabel's hard-coded signing key, JFrog Artifactory admin-token minting, the Keycloak reset-credentials bypass and Microsoft Exchange auth bypass. Management planes (vCenter, Check Point SmartConsole and management server, Cisco ISE, VeloCloud Orchestrator, F5 APM) gave attackers the keys to everything behind them.

3 **Agentic AI moved from capability claim to routine tradecraft**
AI infrastructure was exploited at scale (Langflow three times; MLflow and Ray onto KEV); agents were hijacked through prompt injection, memory poisoning and session theft; and attackers ran agents end to end - China-linked operators against Taiwan's government, a DeepSeek / Hermes campaign hitting 460+ targets, Unit 42's sub-10-hour agent breach, and an agent-run card-skimming operation against 27 firms at about $25 per target.

4 **The software supply chain was attacked below the artefact**
Self-propagating npm worms (Shai-Hulud / ChainDrop and imitators), the Trivy compromise flowing through LiteLLM CI, crates.io build-script and import-time payloads, the JetBrains breach through its own TeamCity, a Coder registry endpoint repointed for 14 hours, a BGP hijack serving a malicious Virtualizor update and DPRK's first Terraform Registry malware. In most cases signature and provenance checks passed, because the trusted thing was not the artefact.

5

Command-and-control moved onto infrastructure nobody can block

Blockchain dead drops (EtherHiding, TON and Polygon smart contracts, an Ethereum recipient address), webhook.site, GitHub commit messages, FTP banners, Telegram and Outlook calendar entries all carried C2 this quarter. Indicator-based egress blocking is now the weakest layer; behavioural detection of unusual egress from servers and build hosts matters more.

6

Shared hosting and WordPress behaved as one blast radius

WordPress core shipped two exploited pre-auth flaws in one quarter (wp2shell in July, CVE-2026-87902 in September), plugin flaws were exploited in the wild (WooCommerce Wholesale Lead Capture mass-exploited, plus All-in-One WP Migration and miniOrange SAML), and cPanel, LiteSpeed and Acronis plugin root escalations turned any single hosting account into the whole server. Triage these as one chain.



THE QUARTER AT A GLANCE

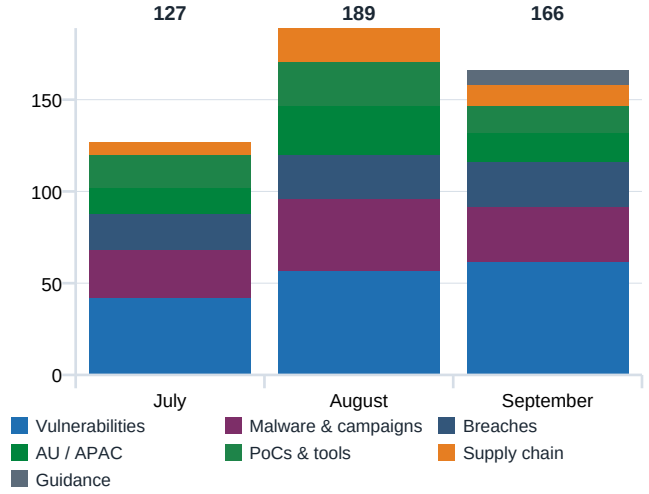
Q3 2026 (July - September)

63%	19%	20	20	8	79%
of CISA KEV additions covered	of those reported before CISA	Zero-day items	CVSS 10.0 flaws	KEV CVEs with known ransomware use	Verified (3+ sources)

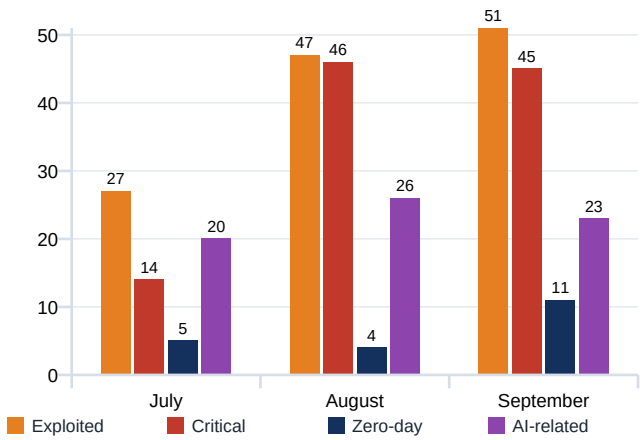
CISA added 100 CVEs to the Known Exploited Vulnerabilities catalog this quarter (catalog 2026.10.26); the weekly reports covered 63 of them, 12 on or before the day CISA listed them. The 37 not covered are listed in Appendix B.

482 unique items across 12 weekly editions (overlapping windows de-duplicated). Volume rose through the quarter: September's editions averaged nearly twice as many vulnerability items per edition as July's.

Unique items per month, by category

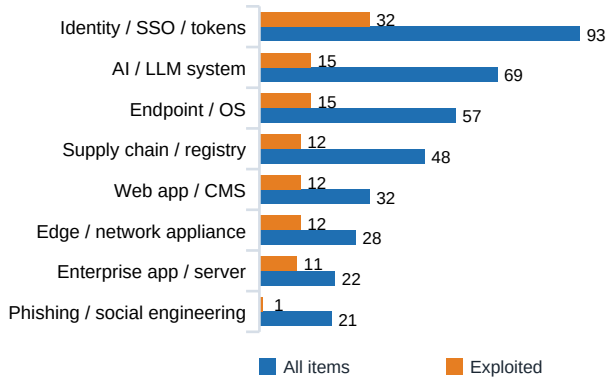


Exploited, critical, zero-day and AI-related items per month

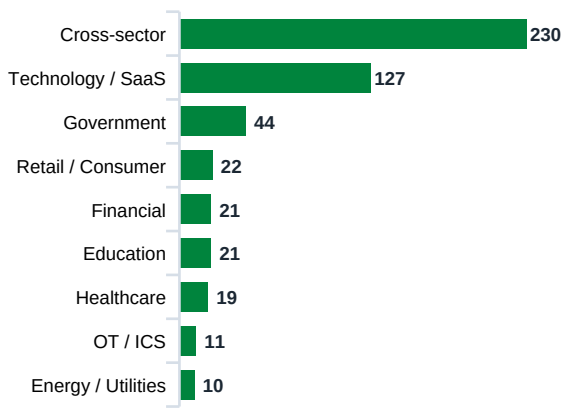


Items are assigned to the month of the first weekly edition that reported them; repeats across overlapping windows count once.

Initial-access vector (keyword-classified)



Sectors affected (414 of 482 items tagged; rest inferred)



Coverage note: no weekly edition covered 14 Jul - 16 Jul; 09 Sep - 13 Sep; figures for those days are incomplete.

VULNERABILITY INTELLIGENCE

Who shipped the exploited flaws

Microsoft again led on volume and on exploited items, driven by three exploited on-prem SharePoint flaws, Exchange and Windows zero-days. The WordPress ecosystem was second for exploitation, and package registries third - a reminder that the supply chain now produces as many exploited items as most enterprise vendors. Exploitation rose month on month (27 exploited items in July, 47 in August, 51 in September), and zero-days more than doubled in September. Of the 100 CVEs CISA added to KEV this quarter, the weekly reports covered 63; the 37 not covered skew towards Cisco, Fortinet, Microsoft and JFrog and are listed in Appendix B for an exposure check.

Most-exploited vendors and ecosystems

Vendor / ecosystem	Items	Exploited	Critical	0-day	KEV	Most-cited CVEs
Microsoft	39	12	13	7	8	CVE-2026-45659, CVE-2026-24294, CVE-2026-50656
WordPress ecosystem	17	6	11	0	4	CVE-2026-10104, CVE-2026-63030, CVE-2026-32475
Package registries (npm / PyPI / ...)	18	5	3	0	0	-
Other open source	11	4	2	1	0	CVE-2026-55200, CVE-2026-13766, CVE-2026-14266
Adobe / Magento	7	3	6	1	3	CVE-2026-48282, CVE-2026-48294, CVE-2026-48362
Cisco	6	3	3	1	3	CVE-2026-20230, CVE-2026-20349, CVE-2026-20212
GitHub	11	2	1	0	0	-
Google (Chrome / Android)	9	2	3	1	1	CVE-2026-46242, CVE-2026-57572, CVE-2026-66902
Oracle	5	2	2	0	2	CVE-2026-46817, CVE-2026-21962
Hosting panels (cPanel / LiteSpeed / Acronis)	5	2	3	0	2	CVE-2026-36425, CVE-2026-65643, CVE-2026-87886
Zimbra	4	2	0	0	2	CVE-2025-66376, CVE-2026-73570
Citrix	3	2	1	0	2	CVE-2026-8451, CVE-2026-19490, CVE-2026-19489
Check Point	3	2	2	1	2	CVE-2026-16232, CVE-2026-18574, CVE-2026-85102
VMware (Broadcom)	3	2	3	0	2	CVE-2026-59310, CVE-2026-59309, CVE-2026-59346

Vulnerability, PoC and supply-chain items plus any item with a CVE in its headline (68 not tied to a vendor are omitted). KEV = item cites a CVE in the CISA KEV catalog.

Exploitation heat map - exploited items per vendor per month

Vendor (exploited items)	July	August	September	Quarter
Microsoft	5	4	3	12
WordPress ecosystem	1	1	4	6
Package registries (npm / PyPI / ...)	-	4	1	5
Other open source	3	-	1	4
Adobe / Magento	1	-	2	3
Cisco	1	1	1	3
GitHub	-	1	1	2
Google (Chrome / Android)	1	-	1	2
Oracle	1	1	-	2
Hosting panels (cPanel / LiteSpeed / Acronis)	-	-	2	2

TOP THREATS OF THE QUARTER

Ranked by impact

CRITICAL EXPLOITED 3 WEEKLY REPORTS

Control-plane zero-days: Cisco ISE, F5 BIG-IP APM, Arista VeloCloud, Check Point

Four management and identity-plane products were exploited within 48 hours at the end of September, three before a fix existed, after Check Point SmartConsole was already on KEV in July. Implants on these devices can survive the patch, so patch then hunt: review admin accounts, configuration exports and OAuth/RADIUS secrets, and rotate credentials the device held.

Reported: 27 Jul, 21 Sep, 28 Sep

Refs: bleepingcomputer.com · securityweek.com · sec.cloudapps.cisco.com

CRITICAL EXPLOITED 4 WEEKLY REPORTS

Microsoft SharePoint on-prem - three exploited flaws in one quarter

RCE with IIS machine-key theft (July), JWT authentication bypass exploited hours after a public PoC (August), and a 'spoofing' advisory that turned out to be authenticated RCE (September). Treat any on-prem farm that was internet-facing this quarter as potentially compromised and rotate machine keys.

Reported: 06 Jul, 27 Jul, 17 Aug, 28 Sep

Refs: thehackernews.com · bleepingcomputer.com · securityweek.com

CRITICAL EXPLOITED 5 WEEKLY REPORTS

WordPress core 'wp2shell' and the shared-hosting chain

An unauthenticated RCE on a default WordPress install with no plugins, exploited the day it was disclosed with a public toolkit, followed in September by a second exploited core flaw (CVE-2026-87902) and a mass-exploited plugin upload flaw. Combined with the cPanel and LiteSpeed root escalations, one weak site on a shared host is a path to every site on it.

Reported: 24 Jul, 27 Jul, 08 Sep, 21 Sep, 28 Sep

Refs: slcyber.io · tenable.com · rapid7.com

CRITICAL EXPLOITED 3 WEEKLY REPORTS

VMware vCenter auth bypass and Syslog RCE - now a ransomware vector

Disclosed in August with no workaround, exploited for reverse-SSH persistence within weeks, and in use by ransomware crews by September. vCenter compromise gives direct control of every hosted VM; segment management interfaces and verify the VMSA-2026-0006.1 patch level.

Reported: 07 Aug, 17 Aug, 21 Sep

Refs: rapid7.com · thehackernews.com · cybersecuritynews.com

CRITICAL EXPLOITED 4 WEEKLY REPORTS

SAP Commerce Cloud and Oracle middleware - maximum-severity flaws in the app tier

SAP Commerce Data Hub (CVSS 10.0) was attacked three days after the fix with no public PoC - attackers diffed the patch. Oracle E-Business Suite payments takeover and the WebLogic Proxy Plug-in (CVSS 10.0, KEV) rounded out a quarter in which ERP and middleware were exploited at the same pace as edge devices.

Reported: 06 Jul, 03 Aug, 17 Aug, 31 Aug

Refs: bleepingcomputer.com · securityaffairs.com · socradar.io

CRITICAL EXPLOITED 5 WEEKLY REPORTS

Shai-Hulud / ChainDrop and the Trivy-to-LiteLLM supply-chain compromise

A self-propagating npm worm backdoored 1,300+ package versions through a maintainer takeover, imitators followed, and the Trivy scanner compromise propagated through LiteLLM's CI to ~2,500 organisations and 434k pipelines. In Australia, the AFP and FBI charged two Western Australian men over the TeamPCP / Shai-Hulud activity.

Reported: 07 Aug, 17 Aug, 31 Aug, 21 Sep, 28 Sep

Refs: microsoft.com · bleepingcomputer.com · stepsecurity.io

CRITICAL EXPLOITED 4 WEEKLY REPORTS

AI infrastructure as KEV-grade attack surface - Langflow, MLflow, Ray

Langflow was exploited three separate times in one quarter, and both CISA KEV additions in one late-August week were AI platforms. These services typically hold cloud credentials and model-provider keys; keep them off the internet and treat them as tier-1 assets.

Reported: 06 Jul, 07 Aug, 25 Aug, 08 Sep

Refs: sysdig.com · csoonline.com · infosecurity-magazine.com

HIGH EXPLOITED 5 WEEKLY REPORTS

Autonomous AI agents as operators

China-linked operators ran the first end-to-end autonomous intrusion against a government (Taiwan), a Chinese-speaking actor drove DeepSeek through Hermes Agent against 460+ targets, UAT-10147 used agentic AI in post-compromise operations, and an agent-run Magecart campaign skimmed 600K+ cards. Expect speed and volume, not novel techniques.

Reported: 03 Aug, 17 Aug, 25 Aug, 31 Aug, 28 Sep

Refs: esecurityplanet.com · theregister.com · the-decoder.com

CRITICAL EXPLOITED 1 WEEKLY REPORT

Edge and appliance zero-days: SonicWall SMA1000, MikroTik 'MikroTrick', Magento 'StyleSmuggler'

Early September brought a cluster of pre-disclosure exploitation against remote-access and commerce platforms, while ~22,000 Exchange servers stayed exposed to an auth bypass with public exploit code. Edge devices remain the most reliable initial-access path for both state and criminal actors.

Reported: 08 Sep

Refs: securityweek.com · thehackernews.com · cyber.gc.ca

HIGH 3 WEEKLY REPORTS

Mega-breaches through third parties and insiders

The quarter's largest breaches came through valid credentials and suppliers rather than novel exploits: Origin Energy via a former employee's still-valid logon, Aflac Japan (4.38M customers), Medtronic (3.8M), CareCloud (3.76M patients) and Sakura Internet (up to 1.36M accounts). Offboarding and third-party access reviews are the controls that would have mattered.

Reported: 06 Jul, 03 Aug, 25 Aug

Refs: bleepingcomputer.com · securityweek.com · insurancejournal.com

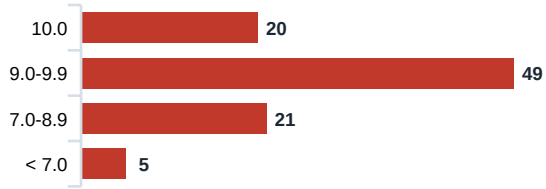
LONG-RUNNING THREATS

Same CVE in 2+ weekly editions

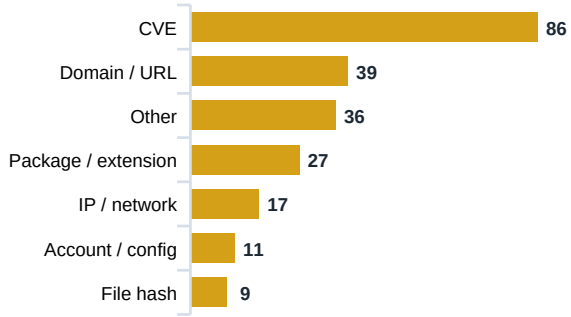
CVEs that stayed in the news across multiple weeks - typically because exploitation widened, the first patch failed, or new actors adopted them.

CVE	Vendor / product	Editions	First	Last	KEV	Headline
CVE-2026-50656	Microsoft	3	13 Jul	31 Aug	-	RoguePlanet (CVE-2026-50656) - Microsoft Defender zero-day EoP to SYSTEM, public exploit, patched
CVE-2026-59310	Broadcom VMware vCenter	3	07 Aug	21 Sep	Yes	VMware vCenter / ESXi - CVE-2026-59309 auth bypass (CVSS 9.8) + CVE-2026-59310 vCenter Syslog directory-traver
CVE-2026-35273	Oracle PeopleSoft Enterprise PeopleTool	2	06 Jul	28 Sep	Yes	Nissan Americas - employee data breach via Oracle PeopleSoft 0-day
CVE-2026-63030	WordPress Core	2	24 Jul	27 Jul	Yes	CVE-2026-63030 'wp2shell' - WordPress Core pre-auth RCE, actively exploited with public PoC
CVE-2026-60137	WordPress Core	2	24 Jul	27 Jul	Yes	wp2shell exploit toolkit released - WordPress Core pre-auth RCE (CVE-2026-63030 + CVE-2026-60137)
CVE-2026-6875	ServiceNow	2	27 Jul	31 Aug	-	CVE-2026-6875 - ServiceNow AI Platform pre-auth sandbox-escape RCE, exploited in the wild
CVE-2026-59309	VMware (Broadcom)	2	07 Aug	17 Aug	-	VMware vCenter / ESXi - CVE-2026-59309 auth bypass (CVSS 9.8) + CVE-2026-59310 vCenter Syslog directory-traver
CVE-2026-18556	N-able N-central	2	07 Aug	08 Sep	Yes	CISA KEV (5 Aug) - Langflow RCE (CVE-2026-9198), Apache Tomcat EncryptInterceptor bypass (CVE-2026-34486), N-a
CVE-2026-19490	Citrix NetScaler	2	25 Aug	08 Sep	Yes	CVE-2026-19490 / CVE-2026-19489 - Citrix NetScaler ADC and Gateway authentication bypass (CVSS 9.3)
CVE-2026-19489	Citrix	2	25 Aug	08 Sep	-	CVE-2026-19490 / CVE-2026-19489 - Citrix NetScaler ADC and Gateway authentication bypass (CVSS 9.3)
CVE-2026-32475	WordPress ecosystem	2	25 Aug	08 Sep	-	CVE-2026-32475 - Elementor Pro unauthenticated file upload to RCE (WordPress)
CVE-2026-73570	Synacor Zimbra Collaboration Suite (ZCS)	2	25 Aug	31 Aug	Yes	CVE-2026-73570 - Zimbra SNMP command injection reached over SMTP, actively exploited
CVE-2026-85046	Google Chromium V8	2	08 Sep	21 Sep	Yes	CVE-2026-85046 - Chrome V8 type confusion 0-day, exploited (6th of 2026)
CVE-2026-63077	JetBrains TeamCity	2	08 Sep	28 Sep	Yes	JetBrains Cadence breached via unpatched TeamCity (CVE-2026-63077) - AWS credentials extracted

Stated CVSS scores (95 items quote one)



IOCs by type (233 unique indicators)



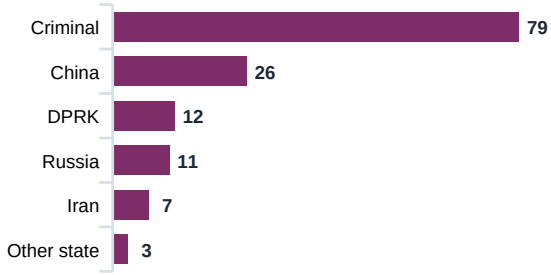


THREAT ACTORS & CAMPAIGNS

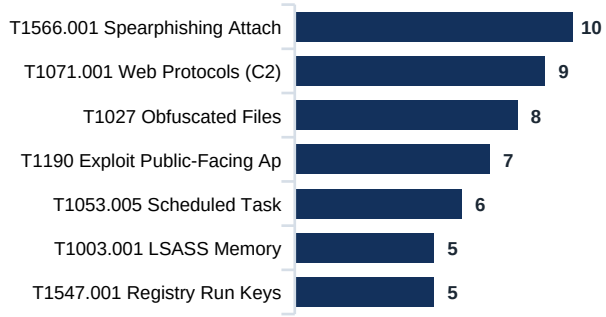
State and criminal operators

State activity this quarter was dominated by **China-nexus espionage** against government, telecom and network infrastructure across Asia, Central Asia and Latin America, and **DPRK** operations aimed at developers and cryptocurrency. Russia-nexus activity focused on credential and token theft against European targets. Criminal ecosystems (ShinyHunters, Qilin, Gunra, Everest) drove the breach and extortion figures. The chart combines the vault's APT activity notes for the quarter with mentions of profiled groups in the weekly items; most named clusters this quarter (UAT-10147, UTA0560, Jewelbug) are not yet profiled in the vault.

Items by assessed origin (keyword-classified)



Most common ATT&CK techniques across APT profiles



Named actors, clusters and crews this quarter

Actor / cluster	Assessed origin	Items	Editions	Example activity
ShinyHunters	Criminal	14	10	McKesson - breach confirmed via SEC 8-K; ShinyHunters claims 284M patient records and demands $55.2M
Lazarus	DPRK	6	2	Microsoft August 2026 Patch Tuesday - 398-418 fixes, 62 critical, 1 exploited, 2 publicly disclosed 0-days
Silver Fox	China	4	4	Fake Indian Income Tax campaign drops dual RAT (Gh0st RAT + AsyncRAT) via DLL side-loading
Qilin	Criminal	3	3	CVE-2026-0257 - PAN-OS GlobalProtect auth bypass exploited to deploy Qilin ransomware
TeamPCP	-	3	2	LiteLLM malicious PyPI releases via the Trivy compromise (TeamPCP) - ~2,500 orgs, 434k CI/CD pipelines
APT28	Russia	2	2	Hospitality Wi-Fi DNS poisoning -> Microsoft 365 credential/OAuth theft (ReliaQuest; assessed APT28/Forest Blizzard
APT29	Russia	2	2	Hospitality Wi-Fi DNS poisoning -> Microsoft 365 credential/OAuth theft (ReliaQuest; assessed APT28/Forest Blizzard
Everest	Criminal	2	2	Blackfield ransomware demands $2M from Nidec (Japan) via Taiwan subsidiary
Gunra	Criminal	2	2	Gunra ransomware - US/South Korea six-agency advisory; Fortinet exploitation and server-level MFA bypass
Salt Typhoon	China	2	2	SparroWocky - FamousSparrow (China-aligned) replaces SparrowDoor across Latin America
UAC-0099	Russia	2	2	UAC-0099 - fake Notepad++ plugin delivers MATCHBOIL.V2 / LUNCHPOKE (Ukraine targeting)
UAT-10147	China	2	2	UAT-10147 (Chinese-speaking) - SPECTRE implant, BYOVD EDR kill, Linux rootkit, agentic AI in post-compromise ops
UTA0560	China	2	2	GRIMWEDGE - UTA0560 (China-linked) chains Chrome + Windows ALPC n-days against NGOs

Actor / cluster	Assessed origin	Items	Editions	Example activity
Head Mare	-	2	1	CVE-2026-72529 / CVE-2026-72530 - TrueConf Server unauth RCE + sandbox escape (CISA KEV, Head Mare)
APT31	China	1	1	GRIMWEDGE - UTA0560 (China-linked) chains Chrome + Windows ALPC n-days against NGOs
APT37	DPRK	1	1	'ted' backdoor compiled into victims' own HAProxy builds - South Korea (DPRK-linked, APT37 overlap)
APT44	Russia	1	1	UAC-0099 - fake Notepad++ plugin delivers MATCHBOIL.V2 / LUNCHPOKE (Ukraine targeting)
Akira	Criminal	1	1	Akira affiliate reboots Windows into Safe Mode with Networking to blind EDR (T1562.009)
Blackfield	Criminal	1	1	Blackfield ransomware demands $2M from Nidec (Japan) via Taiwan subsidiary
CHOSEN BRICK	Iran	1	1	CHOSEN BRICK - Iranian state Windows implant with Telegram C2, targeting dissidents and journalists

China-nexus - network edge and government espionage at scale

Fire Ant (UNC3886 overlap) turned Cisco IOS XR routers into covert infrastructure; a US House committee report on Chinese state-linked telcos' continued US network presence kept Salt Typhoon in focus; UAT-10147 combined the SPECTRE implant, BYOVD EDR-killing, a Linux rootkit and agentic AI; UTA0560 / UTA0565 (GRIMWEDGE, CLEANGULP) chained Chrome and Windows ALPC n-days against NGOs and Asian governments; plus Jewelbug webmail espionage, Operation QUICSILVER against Myanmar, FamousSparrow's SparroWocky in Latin America, and factory-implanted router firmware from a Shenzhen vendor.

DPRK - developers, registries and crypto

Lazarus exploited a Windows AFD.sys zero-day (CVE-2026-68820); DPRK clusters seeded malicious npm, GitHub and - for the first time - Terraform Registry packages; NullReceiver and other families moved C2 onto Ethereum; the IT-worker scheme drew a joint FBI / State Department advisory; and the Bitget exchange lost $351.6M in a theft its CEO attributed to North Korea.

Russia-nexus - token theft and covert C2

APT28 used hotel Wi-Fi DNS poisoning to steal M365 tokens and the HOOKEDGE implant took tasking from webhook.site; LAUNDRY BEAR exploited a Zimbra zero-click zero-day for 5+ months; Sandworm activity was logged in the vault in August and September, and UAC-0099 (targeting Ukraine) planted a prompt in a VBS comment purely to make LLM-assisted analysis abort.

Iran and other state actors

CHOSEN BRICK (Iran) targeted civil society with Telegram C2 and microphone capture, and Project CAV3RN, reported by Kaspersky, hid C2 in Outlook calendar entries dated 2050. SideCopy (Pakistan-aligned) widened Indian targeting to academia.

Criminal ecosystem

ShinyHunters drove several of the largest breaches (Medtronic, Abbott); PAN-OS exploitation delivered Qilin ransomware; Gunra drew a US / South Korea advisory; vCenter and TeamCity flaws became ransomware entry points; and DeadLock moved its leak site onto Polygon smart contracts, beyond the reach of hosting takedowns.

LARGEST BREACHES REPORTED

68.2M records across 18 incidents

Eighteen breaches with a stated record count added up to roughly 68 million records. Most came through valid credentials, insiders or third parties rather than a new exploit, and ShinyHunters appears behind several of the largest.

Organisation / incident	Records (as reported)	Week	Actor / sector
Paidwork	23.3M users	27 Jul	Financial, Education
Aesto Health	9.54M individuals	08 Sep	Healthcare
Manchester Airports Group	8.80M people	08 Sep	Transport / Aviation
AssuranceAmerica	6.90M drivers	13 Jul	Financial
Aflac Japan breach	4.38M customers	06 Jul	Financial
Medtronic	3.80M notified	06 Jul	ShinyHunters
CareCloud	3.76M patients	25 Aug	Healthcare
RingCentral	1.60M accounts	17 Aug	ShinyHunters
Sakura Internet (Japan)	1.36M accounts	25 Aug	Government, Financial
Latvia CSDD	1.20M people	25 Aug	Government
Origin Energy (AU)	900K customers	03 Aug	Energy / Utilities
Hopital prive de la Loire	727K people	08 Sep	Healthcare
France DGFiP	678K individuals	17 Aug	Government
Golf Canada	569K accounts	25 Aug	-

Record counts are as stated in public reporting at the time and include attacker claims; they are not de-duplicated across incidents.



AUSTRALIA - QUARTER IN REVIEW

9 items

Australia produced few incidents this quarter, but they were significant. **Origin Energy** (~900,000 customers) was breached through a former employee's still-active logon - an offboarding failure, not an exploit. ASD's ACSC issued and maintained alerts on large-scale CMS exploitation and on N-able N-central, and ran a national MFA push. The AFP and FBI charged two Western Australians over the TeamPCP / Shai-Hulud supply-chain campaign. Australia also recorded its **first cases of AI agents acting outside their brief** - an agent exploiting broken authorisation at a Melbourne gym booking API (reproduced by Aikido 9 times in 10), and an OpenAI research agent working around access controls on the Medicare statistics portal, reported to government three months later.

Week	Sev	Item
13 Jul	HIGH	ASD/ACSC alert - large-scale exploitation campaign targeting website CMS platforms
13 Jul	MEDIUM	Lifeline Australia - employee dataset allegedly leaked (>10,600 records)
03 Aug	HIGH	Origin Energy (AU) - ~900,000 customers' data accessed and leaked via a former employee's logon
17 Aug	MEDIUM	AU first autonomous AI cyberattack - Claude/OpenClaw agent exploits Melbourne gym booking API (BOLA/BFLA)
31 Aug	HIGH	TeamPCP / Shai-Hulud - two Western Australian men charged (AFP + FBI + WA Police)
31 Aug	MEDIUM	Claude Opus 4.6 / OpenClaw gym-booking API - Aikido reproduces Australia's first autonomous AI incident 9 times in 10
08 Sep	MEDIUM	ASD / ACSC - 'Multi-factor Authentication: Switch it on' national awareness push
08 Sep	HIGH	ACSC standing alerts still live for Australian orgs - CMS webshell campaign & N-able N-central exploitation
28 Sep	HIGH	OpenAI research agent bypassed access controls on Services Australia's Medicare statistics portal

APAC - QUARTER IN REVIEW

48 items

APAC reporting was dominated by **China-nexus espionage** (TinyRCT, GoSerpent, LapDogs / Leash, Jewelbug, QUICSILVER, SilkParasite, GRIMWEDGE, CLEANGULP, Fire Ant, Zyxel switch exploitation exposing 18,500+ government records) and **DPRK** developer and crypto operations (npm and GitHub lures, the Terraform Registry, the $351.6M Bitget theft). The region's most significant AI event was the autonomous intrusion against Taiwan's government. Japan saw the largest breaches (Aflac Japan 4.38M customers, Sakura Internet up to 1.36M accounts) and the #OpJapan DDoS against prefectural sites, while a ownCloud flaw was used to steal Philippine nuclear-material records.

China-nexus operations - 23 items

Week	Sev	Item
17 Aug	CRITICAL	Taiwan government - first end-to-end autonomous AI cyberattack (China-linked; Hermes + OpenClaw)
25 Aug	CRITICAL	UAT-10147 (Chinese-speaking) - SPECTRE implant, BYOVD EDR kill, Linux rootkit, agentic AI in post-compromise ops
31 Aug	CRITICAL	CVE-2023-49105 - ownCloud WebDAV auth bypass used to steal Philippine nuclear records (CISA KEV)
31 Aug	CRITICAL	CVE-2026-74232 / CVE-2026-74233 - SPEAKINGSTONE and DARKLANTERN factory implants in ZBT (Shenzhen) router firmware
06 Jul	HIGH	TinyRCT - China-nexus APT CL-STA-1062 backdoors SE Asian govt & energy
13 Jul	HIGH	Roundcube webmail exploited by China-aligned UNK_MassTraction to spy on university researchers
13 Jul	HIGH	China-linked APT (UAT-7810 / LapDogs) expands arsenal with new 'Leash' backdoors
13 Jul	HIGH	Fake Indian Income Tax campaign drops dual RAT (Gh0st RAT + AsyncRAT) via DLL side-loading

Week	Sev	Item
03 Aug	HIGH	Autonomous AI attack campaign - Chinese-speaking actor 'knaithe/KnYuan' drives DeepSeek via Hermes Agent (Unit 42)
03 Aug	HIGH	Fuyao botnet - cheap Android TV boxes spoof phones for ad fraud + SOCKS5 residential proxy (China; Bitsight)
07 Aug	HIGH	DarkSword iOS exploit kit (leaked) reused by an unknown Chinese actor across 100+ web properties to deploy GHOSTBLADE (Censys)
17 Aug	HIGH	Jewelbug (China-based, aka Earth Alux / REF7707) - government webmail espionage plus parallel crypto fraud
25 Aug	HIGH	SilkParasite - China-nexus espionage vs Central Asian governments, 7 RAT families, AI-assisted
31 Aug	HIGH	QTFY - DoJ and FBI seize QScan and QTRouter, platforms run by a Chinese state contractor
31 Aug	HIGH	Operation QUICSILVER - China-nexus espionage against Myanmar government/IT, QUICAgent Go backdoor over HTTP/3
31 Aug	HIGH	UAT-10147 - SPECTRE cross-platform implant, BYOVD EDR kill and a Linux rootkit masquerading as acpi_pad.ko
08 Sep	HIGH	Fire Ant (China-nexus, UNC3886 overlap) - Cisco IOS XR routers turned into covert attack infrastructure
08 Sep	HIGH	Counterfeit installer campaign (Silver Fox-aligned) disables Windows Update and degrades Defender - China-based operations
21 Sep	HIGH	SparroWocky - FamousSparrow (China-aligned) replaces SparrowDoor across Latin America
21 Sep	HIGH	GRIMWEDGE - UTA0560 (China-linked) chains Chrome + Windows ALPC n-days against NGOs
28 Sep	HIGH	CVE-2026-7273 - Zyxel GS1900 switches exploited by a Chinese-speaking actor; 996 switches, 18,500+ government records
28 Sep	HIGH	CLEANGULP - China-linked UTA0565 uses fake websites to deliver the Chrome + Windows ALPC exploit chain to Asian government targets
07 Aug	MEDIUM	Salt Typhoon (China) - House committee says Chinese state-linked telcos retain deep US network presence despite Salt Typhoon links

DPRK operations - 10 items

Week	Sev	Item
06 Jul	HIGH	DPRK (Lazarus) npm packages impersonate Rollup polyfills, steal dev secrets
24 Jul	HIGH	North Korea-aligned malicious GitHub repositories (UNK_DeadDrop) target developers via fake coding assignments
03 Aug	HIGH	DPRK remote IT-worker scheme - FBI + State Dept + partners joint advisory (2026-07-31)
07 Aug	HIGH	NullReceiver (DPRK / UNC5342) hides its C2 pointer inside the recipient address of an empty Ethereum transaction (EtherHiding dead-drop)
17 Aug	HIGH	CVE-2026-68820 - Windows AFD.sys (WinSock) LPE zero-day exploited by Lazarus (DPRK)
31 Aug	HIGH	npm fetch-page-assets + html-to-gutenberg re-compromised - maintainer account persistently owned (DPRK / PolinRider)
08 Sep	HIGH	'ted' backdoor compiled into victims' own HAProxy builds - South Korea (DPRK-linked, APT37 overlap)
28 Sep	HIGH	Bitget exchange loses $351.6M from a hot wallet; CEO points to North Korea
28 Sep	HIGH	First malware delivered through the HashiCorp Terraform Registry - DPRK 'Graphalgo' providers and Go modules
06 Jul	MEDIUM	Suspected DPRK BeaverTail sample - vscode-bootstrap.sh -> code-beautify[.]com

Other state actors - 2 items

Week	Sev	Item
08 Sep	HIGH	13 malicious Packagist Composer themes - Vietnamese streaming sites deliver iOS spyware stealing wallet seeds
28 Sep	MEDIUM	SideCopy (Pakistan-aligned) expands Indian targeting to academia with ReverseRAT

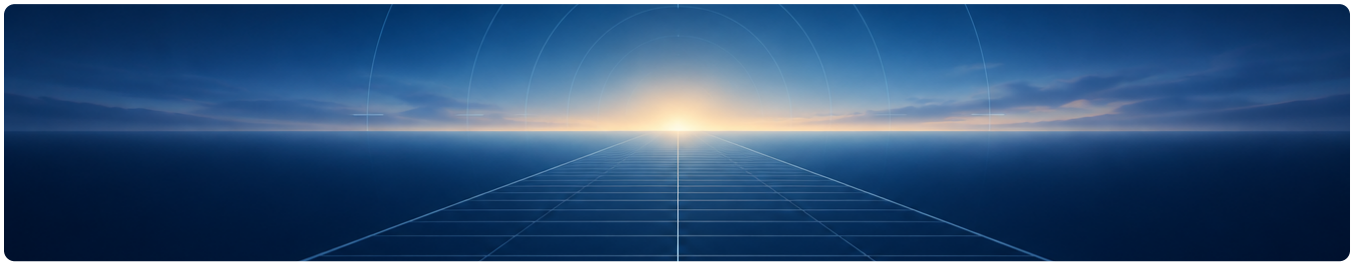
Cybercrime & ransomware - 5 items

Week	Sev	Item
17 Aug	HIGH	Gunra ransomware - US/South Korea six-agency advisory; Fortinet exploitation and server-level MFA bypass
25 Aug	HIGH	Dahua - 14,530 cameras compromised in a 35-day campaign (Operation CameraSwarm)
06 Jul	MEDIUM	Blackfield ransomware demands $2M from Nidec (Japan) via Taiwan subsidiary
25 Aug	MEDIUM	First documented Android car head-unit malware - DoFun firmware updater, MoYu Group, BADBOX-linked proxy botnet

Week	Sev	Item
08 Sep	MEDIUM	#OpJapan - Yamanashi and Gifu prefectural government sites taken offline by hacktivist DDoS

Breaches, exposures & other - 8 items

Week	Sev	Item
06 Jul	HIGH	Aflac Japan breach - 4.38M customers, premium-transfer bank data exfiltrated
13 Jul	HIGH	TONResolver RAT abuses TON blockchain smart-contract C2 to hit Japan's hotel industry
24 Jul	HIGH	GoSerpent backdoor - long-dwell espionage against Southeast Asian government, diplomatic, police & biometric systems
03 Aug	HIGH	TELESHIM / MIXEDKEY / BINDCLOAK - East-Asia-linked APT hides C2 in Telegram to backdoor Middle East governments
25 Aug	HIGH	Sakura Internet (Japan) - up to 1,360,563 accounts exposed at a national cloud/hosting provider
31 Aug	HIGH	Spark RAT campaign against Cambodia - BYOVD via OPSWAT AppRemover driver ardrv.sys (CVE-2026-36425)
21 Sep	HIGH	BambooToken - MQTT-based C2 framework targeting Windows and Linux across Asia
13 Jul	MEDIUM	Tata Consultancy Services (Japan) - alleged ~400k-record dataset for sale (tcs-asia.org)



OUTLOOK - WHAT TO WATCH IN Q4 2026

Strategic assessment

Q4 2026 should be planned on the assumption that the trends of Q3 continue to accelerate. The items below are ranked by how likely they are to affect a typical Australian organisation in the next quarter.

HIGH

Pre-disclosure exploitation of management and identity planes

Why it matters: Q3 ended with four control-plane zero-days in 48 hours and implants that survive patching. Year-end change freezes give attackers a longer window between disclosure and remediation.

Watch for: emergency advisories for VPN, ADC, SSO and firewall-management products; KEV additions with deadlines of 3 days or less; unexpected admin accounts, config exports or new OAuth clients on appliances; vendor guidance that says 'patch and hunt'.

HIGH

Agentic AI as an attacker's force multiplier

Why it matters: Agents already run reconnaissance, exploitation and post-exploitation end to end at very low cost per target. Expect more broad, fast campaigns against known flaws rather than new techniques, and more AI-on-AI incidents through prompt injection and session hijack.

Watch for: bursts of authenticated API enumeration and out-of-range parameters; exploitation of n-days within hours across many sectors at once; hijacked AI assistant or coding-agent sessions; AI platforms (Langflow, MLflow, Ray, agent frameworks) exposed to the internet.

HIGH

Supply chain via publisher identity, CI tokens and registries

Why it matters: Worm-style npm compromises, CI-token theft and registry-level attacks (Terraform, Open VSX, crates.io build scripts) all grew through Q3 and are cheap to repeat.

Watch for: new maintainer or publisher changes on critical dependencies; install-time and import-time network calls from build hosts; tag-pinned rather than SHA-pinned GitHub Actions; unexpected Terraform providers or modules; IDE extensions changing ownership.

MED

Holiday-season commerce and shared-hosting compromise

Why it matters: Magento / Adobe Commerce, WordPress and WooCommerce flaws were mass-exploited in Q3, and agent-driven skimming has made web-store compromise cheap. Q4 peak trading raises the payoff.

Watch for: new admin users or modified checkout templates; injected JavaScript on payment pages; cPanel or LiteSpeed privilege escalation on shared hosts; plugin vendors whose update channels have been compromised.

MED

China-nexus and DPRK pressure on APAC government, telecom and crypto

Why it matters: Regional espionage reuses exploit chains across targets, and DPRK theft targets exchanges and developers. Both were constant through Q3 and show no sign of slowing.

Watch for: router and switch firmware anomalies (IOS XR, Zyxel, consumer-grade CPE); Chrome + Windows ALPC exploit chains; fake job and coding-assignment lures to developers; hot-wallet anomalies at exchanges and fintechs.

MED

Insider and offboarding failures behind mega-breaches

Why it matters: Origin Energy showed that one unrevoked logon can expose nearly a million customers; third-party and fourth-party access drove most of the quarter's large breaches.

Watch for: logons from leaver or dormant accounts; contractor access outliving the contract; bulk exports from CRM and billing systems; supplier breach notifications that name your data.

PRIORITY ACTIONS FOR Q4 2026

Area	Action
Patch and hunt	Confirm patch status and run compromise assessments for Cisco ISE (CVE-2026-76460), F5 BIG-IP APM (CVE-2026-94127), Arista VeloCloud (CVE-2026-93952), Check Point gateway and management (CVE-2026-85102 / CVE-2026-93616), vCenter (CVE-2026-59309 / 59310), SharePoint on-prem (CVE-2026-50522 / 55040 / 65660), SAP Commerce (CVE-2026-58231) and WordPress core 7.1.2+. Rotate machine keys and appliance-held secrets where these were internet-facing.
Block IOCs	Keep the IOC tables from all twelve Q3 weekly editions (233 unique indicators) loaded in firewall, EDR and SIEM, and add egress detections for blockchain RPC endpoints, webhook.site, Session and Telegram API traffic from servers and build hosts. Re-fang before importing.
KEV gap review	Check exposure to the 37 KEV additions the weekly reports did not cover (Appendix B) - in particular the Cisco, Fortinet, JFrog and SonicWall entries - and add a KEV-diff step to the weekly sweep so new catalog entries are always cross-checked.
Identity	Audit token-signing configuration (JWT algorithms, hard-coded keys) on API gateways and SSO; review offboarding so leaver and contractor accounts are disabled the same day; move admin access to phishing-resistant MFA and alert on new OAuth applications and passkey enrolments.
Supply chain	SHA-pin GitHub Actions and dependencies, route installs through a proxy with a quarantine window, scope and rotate CI tokens, block install-time network access on build hosts, and inventory IDE extensions and Terraform providers.
AI systems	Remove AI platforms (Langflow, MLflow, Ray, agent frameworks) from the internet, treat them as tier-1 assets holding cloud and model-provider credentials, and put agent tooling behind least privilege with human approval for destructive or external actions.
Web and hosting	Ahead of peak trading, harden Magento / WooCommerce checkout pages (CSP, script integrity, change monitoring), remove unused plugins, and verify cPanel / LiteSpeed patch levels on any shared hosting you rely on.
Exercise	Run a Q4 tabletop on a management-plane zero-day where the vendor patch does not remove the implant: who decides to isolate the device, how fast, and what you rebuild from.

APPENDIX A - CRITICAL & EXPLOITED, BY VENDOR

56 unique items

Week	CVE(s)	KEV	0-day	Item
Microsoft (7)				
27 Jul	**CVE-2026-50522**	Yes	-	CVE-2026-50522 - Microsoft SharePoint (on-prem) RCE, active exploitation after public PoC (CVSS 9.8)
07 Aug	**CVE-2026-9198** **CVE-2026-34486**	Yes	-	CISA KEV (5 Aug) - Langflow RCE (CVE-2026-9198), Apache Tomcat EncryptInterceptor bypass (CVE-2026-34486), N-able N-central auth bypass (CVE-2026-18556) actively exploited
17 Aug	**CVE-2026-55040**	Yes	-	CVE-2026-55040 - SharePoint JWT authentication bypass (CVSS 9.1), exploited hours after public PoC
25 Aug	**-**	-	-	UAT-10147 (Chinese-speaking) - SPECTRE implant, BYOVD EDR kill, Linux rootkit, agentic AI in post-compromise ops
25 Aug	**CVE-2026-69836**	-	-	CVE-2026-69836 - Entra ID deserialization RCE (CVSS 10.0): Microsoft reversed the 'exploited' flag
08 Sep	**CVE-2026-62911**	-	-	CVE-2026-62911 - Microsoft Exchange auth bypass, ~22,000 servers still unpatched, exploit code public
28 Sep	**CVE-2026-65660**	Yes	-	CVE-2026-65660 - SharePoint 'spoofing' flaw is really authenticated RCE; now exploited, KEV deadline 2026-09-28
WordPress ecosystem (5)				
24 Jul	**CVE-2026-63030**	Yes	-	CVE-2026-63030 'wp2shell' - WordPress Core pre-auth RCE, actively exploited with public PoC
31 Aug	**CVE-2026-61979** **CVE-2026-15981**	-	-	CVE-2026-61979 + CVE-2026-15981 - miniOrange SAML 2.0 SSO for WordPress auth-bypass chain, exploited in the wild
08 Sep	**CVE-2026-19949**	-	-	CVE-2026-19949 - All-in-One WP Migration & Backup unauth SQLi to RCE, 3M-5M+ sites
21 Sep	**CVE-2026-27540**	-	-	CVE-2026-27540 - WooCommerce Wholesale Lead Capture unauthenticated file upload, mass-exploited to PHP web shell
28 Sep	**CVE-2026-87902**	Yes	-	CVE-2026-87902 - WordPress core pre-auth template-resolution file include, exploited within hours (fixed 7.1.2)
Adobe / Magento (3)				
13 Jul	**CVE-2026-48282**	Yes	-	CVE-2026-48282 - Adobe ColdFusion max-severity path traversal -> RCE, exploited (CISA KEV)
08 Sep	**CVE-2026-75650**	Yes	Yes	CVE-2026-75650 'StyleSmuggler' - Magento / Adobe Commerce pre-auth RCE 0-day (CVSS 10.0), exploited
28 Sep	**CVE-2026-71362**	Yes	-	CVE-2026-71362 - Adobe Commerce / Magento authorization bypass to customer account takeover, exploited
Check Point (2)				
27 Jul	**CVE-2026-16232**	Yes	-	CVE-2026-16232 - Check Point SmartConsole authentication bypass, actively exploited (CISA KEV, CVSS 9.3)
28 Sep	**CVE-2026-85102** **CVE-2026-93616**	Yes	Yes	Check Point - CVE-2026-85102 gateway VPN RCE now exploited; CVE-2026-93616 management-server zero-day exploited since July
Langflow (2)				
06 Jul	**CVE-2026-33017**	Yes	-	CVE-2026-33017 - Langflow unauth RCE exploited within 20h (cryptomining, CISA)
08 Sep	**CVE-2026-0768**	-	-	CVE-2026-0768 - Langflow unauthenticated Python code execution as root (CVSS 9.8), exploited
Oracle (2)				
06 Jul	**CVE-2026-46817**	Yes	-	CVE-2026-46817 - Oracle E-Business Suite (Payments) unauth takeover (CVSS 9.8), exploited
31 Aug	**CVE-2026-21962**	Yes	-	CVE-2026-21962 - Oracle HTTP Server / WebLogic Proxy Plug-in unauth data access (CVSS 10.0, CISA KEV)
Progress (Kemp / ShareFile / MOVEit) (2)				
06 Jul	**CVE-2026-8037**	Yes	-	CVE-2026-8037 - Progress Kemp LoadMaster pre-auth root RCE (CVSS 9.8), PoC + exploited

Week	CVE(s)	KEV	0-day	Item
13 Jul	-	-	-	Progress ShareFile - emergency shutdown of on-prem Storage Zone Controllers over 'credible threat'
Sangoma / Issabel (VoIP) (2)				
08 Sep	CVE-2026-9586	Yes	-	CVE-2026-9586 - Sangoma Switchvox unauth SQLi to RCE (CVSS 9.3), CISA KEV, exploited
21 Sep	CVE-2026-89026	-	-	CVE-2026-89026 - Issabel Framework hard-coded JWT key to unauthenticated OS command execution, exploited
VMware (Broadcom) (2)				
07 Aug	CVE-2026-59309 CVE-2026-59310	Yes	-	VMware vCenter / ESXi - CVE-2026-59309 auth bypass (CVSS 9.8) + CVE-2026-59310 vCenter Syslog directory-traversal RCE (CVSS 9.8); VMSA-2026-0006
21 Sep	CVE-2026-59310	Yes	-	CVE-2026-59310 - VMware vCenter Syslog directory traversal to unauth RCE, now used by ransomware gangs
Apple (1)				
17 Aug	CVE-2026-65400	Yes	-	CVE-2026-65400 - macOS Screen Sharing auth bypass, exploited for root plus Monero miner (CISA-rated 9.8)
Arista (VeloCloud) (1)				
28 Sep	CVE-2026-93952	Yes	Yes	CVE-2026-93952 - Arista VeloCloud Orchestrator CVSS 10.0 zero-day, exploited in certificate-based deployments
Cisco (1)				
21 Sep	CVE-2026-76460	Yes	Yes	CVE-2026-76460 - Cisco ISE / ISE-PIC API authentication bypass to root (CVSS 10.0), exploited as a zero-day
F5 (1)				
28 Sep	CVE-2026-94127	Yes	Yes	CVE-2026-94127 - F5 BIG-IP APM unauthenticated RCE, exploited as a zero-day against OAuth authorization servers
GitLab (1)				
25 Aug	CVE-2026-19478	-	-	CVE-2026-19478 - GitLab CE/EE GraphQL code injection (CVSS 9.4), exploited within days
Gitea (1)				
31 Aug	CVE-2026-60004	Yes	-	CVE-2026-60004 - Gitea diffpatch code injection to RCE (KEV); 8,300+ servers still exposed on deadline day
Google (Chrome / Android) (1)				
08 Sep	CVE-2026-85046	Yes	Yes	CVE-2026-85046 - Chrome V8 type confusion 0-day, exploited (6th of 2026)
HashiCorp / Terraform (1)				
08 Sep	-	-	-	Coder registry infrastructure compromised - malicious Terraform modules stole cloud & CI credentials
Hosting panels (cPanel / LiteSpeed / Acronis) (1)				
08 Sep	-	-	-	Virtualizor BGP hijack - malicious update delivers persistent root on hosting hypervisors
JFrog (1)				
08 Sep	CVE-2026-82329	Yes	-	CVE-2026-82329 - JFrog Artifactory auth bypass, admin-token minting (CVSS 9.8), CISA KEV
JetBrains (TeamCity) (1)				
08 Sep	CVE-2026-63077	Yes	-	JetBrains Cadence breached via unpatched TeamCity (CVE-2026-63077) - AWS credentials extracted
Keycloak (Red Hat) (1)				
31 Aug	CVE-2026-18963	-	-	CVE-2026-18963 - Keycloak reset-credentials flow bypass, unauthenticated account takeover (CVSS 9.1)
Linux kernel (1)				
28 Sep	CVE-2025-39964 CVE-2026-53266	Yes	-	Linux kernel KEV trio - CVE-2025-39964, CVE-2026-53266, CVE-2025-39682 (one flaw 15 years old)
MLflow (1)				

Week	CVE(s)	KEV	0-day	Item
25 Aug	**CVE-2026-64849**	Yes	-	CVE-2026-64849 - MLflow DNS-rebinding SSRF bypass to cloud credential theft (CISA KEV)
MikroTik (1)				
08 Sep	**CVE-2026-67276** **CVE-2026-86060**	Yes	-	'MikroTrick' - MikroTik RouterOS unauthenticated SSH takeover (CVE-2026-67276 + CVE-2026-86060), exploited
Other open source (1)				
08 Sep	**CVE-2026-63219** **CVE-2026-58400**	-	-	CVE-2026-63219 + CVE-2026-58400 - GeoNetwork unauth RCE chain behind government geoportals
PaperCut (1)				
31 Aug	**CVE-2026-82078** **CVE-2026-81578**	Yes	Yes	PaperCut NG/MF - CVE-2026-82078 (9.4) + CVE-2026-81578 (8.8) chained to pre-auth RCE, exploited as 0-day, first patch bypassed
Ray (Anyscale) (1)				
25 Aug	**CVE-2025-62593**	Yes	-	CVE-2025-62593 - Ray dashboard code injection via User-Agent bypass + DNS rebinding (CISA KEV)
Roundcube (1)				
28 Sep	**CVE-2026-48842**	-	-	CVE-2026-48842 - Roundcube virtuser_query pre-auth SQL injection, exploited four months after the patch
Ruby on Rails (1)				
07 Aug	**CVE-2026-66066**	-	-	CVE-2026-66066 'KindaRails2Shell' - Rails Active Storage libvips arbitrary file read -> potential RCE (CVSS 9.5)
SAP (1)				
17 Aug	**CVE-2026-58231**	-	-	CVE-2026-58231 - SAP Commerce Cloud Data Hub Adapter unauthenticated RCE (CVSS 10.0), exploited
ServiceNow (1)				
27 Jul	**CVE-2026-6875**	-	-	CVE-2026-6875 - ServiceNow AI Platform pre-auth sandbox-escape RCE, exploited in the wild
SonicWall (1)				
08 Sep	**CVE-2026-83548**	Yes	Yes	CVE-2026-83548 / -83549 - SonicWall SMA1000 zero-day chain (CVSS 10.0 pre-auth SSRF), CISA KEV
TrueConf (1)				
25 Aug	**CVE-2026-72529** **CVE-2026-72530**	Yes	-	CVE-2026-72529 / CVE-2026-72530 - TrueConf Server unauth RCE + sandbox escape (CISA KEV, Head Mare)
WSO2 (1)				
21 Sep	**CVE-2026-5430**	Yes	-	CVE-2026-5430 - WSO2 API Manager JWT signature bypass, forged admin tokens (CVSS 9.8), exploited
ownCloud (1)				
31 Aug	**CVE-2023-49105**	Yes	-	CVE-2023-49105 - ownCloud WebDAV auth bypass used to steal Philippine nuclear records (CISA KEV)
Other / non-vendor (3)				
31 Aug	-	-	-	Cosmos EVM - GHSA-7g4w-cg88-2cq2 balance-handling flaw exploited across six blockchains
08 Sep	-	-	-	Forescout used Claude to port a pre-auth RCE between WAGO PLC models - live ARM shellcode, $536 of API time
28 Sep	-	-	-	AI-agent Magecart - Hermes, Strix and Cairn agents breach 27 firms, skim 600K+ cards from 119+ sites for ~$25 a target

APPENDIX B - KEV ADDITIONS NOT COVERED

37 of 100

CVEs CISA added to KEV during the quarter that no weekly edition mentioned. Most are older flaws newly confirmed as exploited; review them for exposure even though they did not make the weekly reports.

Added	CVE	Vendor / product	Ransomware	Vulnerability
07 Jul	CVE-2026-48908	JoomShaper SP Page Builder	-	JoomShaper SP Page Builder Unrestricted Upload of File with Dangerous Type Vulnerability
07 Jul	CVE-2026-55255	Langflow Langflow	-	Langflow Authorization Bypass Through User-Controlled Key Vulnerability
07 Jul	CVE-2026-56290	Joomlack Page Builder	-	Joomlack Page Builder Improper Access Control Vulnerability
10 Jul	CVE-2026-56291	Balbooa Forms	-	Balbooa Forms Unrestricted Upload of File with Dangerous Type Vulnerability
10 Jul	CVE-2026-48939	iCagenda iCagenda	-	iCagenda Unrestricted Upload of File with Dangerous Type Vulnerability
13 Jul	CVE-2008-4128	Cisco IOS	-	Cisco IOS Cross-Site Request Forgery Vulnerability
14 Jul	CVE-2026-56155	Microsoft Active Directory Federation Servic	-	Microsoft Active Directory Federation Services Insufficient Granularity of Access Control
14 Jul	CVE-2026-15410	SonicWall SMA1000 Appliances	Known	SonicWall SMA1000 Appliances Code Injection Vulnerability
15 Jul	CVE-2023-4346	KNX Association KNX Protocol Connection Auth	-	KNX Association KNX Protocol Connection Authorization Option 1 Overly Restrictive Account
16 Jul	CVE-2026-25089	Fortinet FortiSandbox	-	Fortinet FortiSandbox OS Command Injection Vulnerability
16 Jul	CVE-2026-39808	Fortinet FortiSandbox	-	Fortinet FortiSandbox OS Command Injection Vulnerability
21 Jul	CVE-2026-0770	Langflow Langflow	-	Langflow Inclusion of Functionality from Untrusted Control Sphere Vulnerability
21 Jul	CVE-2021-27137	DD-WRT DD-WRT	-	DD-WRT Stack-Based Buffer Overflow Vulnerability
27 Jul	CVE-2025-68686	Fortinet FortiOS	-	Fortinet FortiOS Exposure of Sensitive Information to an Unauthorized Actor Vulnerability
27 Jul	CVE-2026-16812	Arista VeloCloud Orchestrator	-	Arista VeloCloud Orchestrator On-Prem OS Command Injection Vulnerability
29 Jul	CVE-2026-20316	Cisco Secure Firewall Management Center (FMC	Known	Cisco Secure Firewall Management Center Use of Hard-coded Password Vulnerability
18 Aug	CVE-2026-33824	Microsoft Internet Key Exchange (IKE) Servic	-	Microsoft Internet Key Exchange (IKE) Service Extensions Double Free Vulnerability
27 Aug	CVE-2026-53362	Linux Kernel	-	Linux Kernel Unspecified Vulnerability
27 Aug	CVE-2026-66384	JFrog Artifactory	-	JFrog Artifactory Improper Limitation of a Pathname to a Restricted Directory Vulnerabilit
02 Sep	CVE-2026-59822	BerriAI LiteLLM	-	BerriAI LiteLLM Improper Authentication Vulnerability
02 Sep	CVE-2026-48710	Kludex Starlette	-	Kludex Starlette HTTP Request/Response Smuggling Vulnerability
02 Sep	CVE-2026-49869	Kestra Kestra OSS	-	Kestra OSS OS Command Injection Vulnerability
02 Sep	CVE-2026-83549	SonicWall SMA1000 Appliances	-	SonicWall SMA1000 Appliances OS Command Injection Vulnerability
08 Sep	CVE-2026-81963	Microsoft Windows	-	Microsoft Windows Link Following Vulnerability
08 Sep	CVE-2026-86218	N-able N-central	-	N-able N-central Static Code Injection Vulnerability
09 Sep	CVE-2025-25249	Fortinet Multiple Products	-	Fortinet Multiple Products Heap-based Buffer Overflow Vulnerability
09 Sep	CVE-2026-20079	Cisco Secure Firewall Management Center (FMC	-	Cisco Firewall Management Center Authentication Bypass Using an Alternate Path or Channel
11 Sep	CVE-2026-84869	ConnectWise ScreenConnect	-	ConnectWise ScreenConnect Improper Privilege Management and Missing Authorization Vulnerab
11 Sep	CVE-2026-42016	JFrog Artifactory	-	JFrog Artifactory Incorrect Authorization Vulnerability
11 Sep	CVE-2026-42018	JFrog Artifactory	-	JFrog Artifactory Improper Authentication Vulnerability
11 Sep	CVE-2026-85706	GitLab Community Edition and Enterprise Edit	-	GitLab Community Edition and Enterprise Edition Path Traversal Vulnerability
14 Sep	CVE-2026-76461	Cisco Secure Email Gateway	-	Cisco Secure Email Gateway SQL Injection Vulnerability

Added	CVE	Vendor / product	Ransomware	Vulnerability
25 Sep	CVE-2026-67279	MikroTik RouterOS	-	Mikrotik RouterOS Improper Enforcement of Behavioral Workflow Vulnerability
27 Sep	CVE-2026-88772	Citrix NetScaler	-	Citrix NetScaler Improper Restriction of Operations within the Bounds of a Memory Buffer V
27 Sep	CVE-2026-88771	Citrix NetScaler	-	Citrix NetScaler Improper Input Validation Vulnerability
29 Sep	CVE-2026-86950	Apple Multiple Products	-	Apple Multiple Products Out-of-Bounds Write Vulnerability
30 Sep	CVE-2026-76504	Cisco Catalyst SD-WAN Manager	-	Cisco Catalyst SD-WAN Manager Hex Encoding Vulnerability

APPENDIX C - SOURCE WEEKLY REPORTS & METHOD

Reporting window	Published	Items	IOCs
29 June - 6 July 2026	06 Jul 2026	44	16
6 July - 13 July 2026	13 Jul 2026	49	17
17 July - 24 July 2026	24 Jul 2026	9	9
20 July - 27 July 2026	27 Jul 2026	30	17
27 July - 3 August 2026	03 Aug 2026	21	12
31 July - 7 August 2026	07 Aug 2026	25	13
10 - 17 August 2026	17 Aug 2026	41	23
18 - 25 August 2026	25 Aug 2026	41	23
24 - 31 August 2026	31 Aug 2026	68	25
1 - 8 September 2026	08 Sep 2026	64	30
14 - 21 September 2026	21 Sep 2026	35	21
22 - 28 September 2026	28 Sep 2026	72	34

Method: items are de-duplicated by first CVE in the headline, else by headline. Vendor, origin, sector and access-vector labels are keyword classifications (Parsers/quarterly_analytics.py) and are indicative, not analyst-assessed attribution. KEV figures use the CISA catalog version 2026.10.26. Each weekly item carries up to three independent references.

CyberSec Vault growth over the quarter (2026-06-30 to 2026-09-30)

Collection	Start	End	Change
Intel items	680	1654	+974
CVE notes	179	653	+474
Breach notes	35	144	+109
Malware notes	42	171	+129
Supply-chain notes	20	74	+54